

Table of Contents

Status da revisão: Edição de revisão controlada. Requer validação humana de terminologia, significado, links, formatação, acessibilidade e atualidade técnica antes da publicação final.

SÉRIE PRÁTICA DE CIBERSEGURANÇA, PRIVACIDADE E CONFORMIDADE

CIS Critical Security Controls v8.1

Implementação prática, medição, evidências e ferramentas de código aberto

Manual de trabalho para gestores, analistas juniores, estudantes, profissionais em transição de carreira, avaliadores e equipes de segurança

Alberto (Al) Leiva

Primeira edição • Julho de 2026

Conteúdo: 18 Controles • 153 Salvaguardas • IG1, IG2 e IG3 • medição • evidências • ferramentas • guia para gestores • laboratórios • preparação profissional

Aviso de publicação e uso

Autor: Alberto (Al) Leiva

Edição: Primeira edição, julho de 2026

Este manual educacional independente não é uma publicação, certificação, acreditação, relatório de auditoria, opinião jurídica ou garantia de segurança ou conformidade emitida pelo Center for Internet Security. CIS Controls e CIS Benchmarks são marcas do Center for Internet Security. Consulte os recursos oficiais do CIS para obter o conteúdo exato e a orientação vigente.

Os CIS Controls representam boas práticas de cibersegurança. Eles não substituem leis, regulamentos, contratos, requisitos setoriais, avaliações de risco ou responsabilidades de gestão aplicáveis. Um mapeamento demonstra relações entre estruturas; não comprova automaticamente a conformidade com outra estrutura.

Uso ético e autorizado

Utilize ferramentas técnicas somente em ativos, redes, aplicações, contas de nuvem, repositórios e dados que você possui ou para os quais recebeu autorização específica por escrito. Em laboratórios, utilize informações sintéticas e sistemas isolados.

Prefácio

Introdução prática à defesa cibernética priorizada e à medição baseada em evidências.

Os CIS Controls transformam necessidades defensivas comuns em Salvaguardas específicas. Sua principal força é a priorização prática: conhecer os ativos, controlar software e dados, proteger configurações e identidades, gerenciar vulnerabilidades e registros, preparar-se para interrupções e ataques e testar se as defesas funcionam.

A versão 8.1 é uma atualização iterativa da versão 8. Ela realinhou os mapeamentos ao NIST CSF 2.0, ampliou definições de termos reservados, revisou classes de ativos e mapeamentos de Salvaguardas, corrigiu questões menores, esclareceu determinadas Salvaguardas e incorporou a função Governar aos mapeamentos. Os 18 Controles e as 153 Salvaguardas permanecem como estrutura central.

A instalação de uma ferramenta não equivale à implementação de um controle. Uma implementação efetiva exige escopo definido, populações completas, configuração segura, evidência operacional, responsáveis capacitados, tratamento de exceções, medição, correção e novos testes. Gestores definem prioridades e recursos; analistas tornam essas decisões confiáveis por meio de inventários e evidências precisos.

Como usar este manual

- Gestores devem começar pelos capítulos 1–5 e 24–25.
- Analistas juniores devem estudar os 18 capítulos de Controles, o método de medição, as ferramentas, o laboratório e o capítulo de entrevistas.
- Equipes técnicas devem relacionar cada Salvaguarda a ativos, dados, responsáveis, procedimentos, configurações, monitoramento, exceções e evidências.
- Avaliadores devem utilizar a especificação oficial de avaliação dos CIS Controls para confirmar entradas, operações, medidas, métricas, premissas e revisões de procedimentos.

Sumário no Word: O arquivo DOCX pode conter um campo nativo de sumário. Após qualquer edição, atualize o campo e selecione a opção para atualizar a tabela inteira.

Sumário

1. Fundamentos dos CIS Controls v8.1
2. Grupos de Implementação e priorização
3. Governança, escopo e responsabilidades
4. Medição com a especificação de avaliação do CIS

5. Roteiro de implementação
6–23. Os 18 CIS Controls
6. Ferramentas de código aberto
7. Guia dos CIS Controls para gestores
8. Guia profissional para analistas juniores
9. Laboratório fictício e portfólio
10. Plano de aprendizagem de trinta dias
11. Preparação para entrevistas
12. Modelos, glossário, índice e referências

1. Fundamentos dos CIS Controls v8.1

A versão atual, sua estrutura, finalidade e limitações.

Figura 1. Os 18 CIS Critical Security Controls

- Os CIS Controls v8.1 foram publicados em junho de 2024.
- Os Controles são boas práticas priorizadas para defender sistemas e redes contra ataques prevalentes.
- A estrutura contém 18 Controles e 153 Salvaguardas.
- As Salvaguardas são relacionadas a classes de ativos, funções de segurança e Grupos de Implementação.
- A versão 8.1 alinha o mapeamento ao NIST CSF 2.0 e inclui a função Governar.
- Existem mapeamentos oficiais para várias estruturas, mas cada requisito aplicável deve ser verificado separadamente.

Camada	Finalidade
Controle	Resultado defensivo amplo, como inventário de ativos ou resposta a incidentes.
Salvaguarda	Ação específica que pode ser atribuída, implementada e medida.
Classe de ativo	Tipo de elemento afetado, como dispositivos, software, dados, redes, usuários ou documentação.
Função de segurança	Mapeamento para Governar, Identificar, Proteger, Detectar, Responder ou Recuperar.

Camada	Finalidade
Grupo de Implementação	Priorização recomendada de acordo com o perfil de risco e os recursos.
Medida de avaliação	Entradas, operações, medidas, métricas e revisão de procedimentos usadas para avaliar uma Salvaguarda.

2. Grupos de Implementação e priorização

Como IG1, IG2 e IG3 ajudam organizações a escolher um ponto de partida realista.

Figura 2. Progressão dos Grupos de Implementação

Grupo	Salvaguardas	Situação típica	Objetivo
IG1	56	Recursos e experiência de segurança limitados; menor sensibilidade; necessidade elevada de continuidade básica.	Higiene cibernética essencial contra ataques comuns.
IG2	IG1 + 74	Vários departamentos, maior complexidade, informações sensíveis e maior dependência operacional.	Gerenciar riscos e complexidade operacional crescentes.
IG3	IG1 + IG2 + 23 = 153	Especialistas em segurança, dados sensíveis ou regulamentados, serviços críticos e ameaças sofisticadas.	Reduzir o impacto de ataques direcionados e avançados.

- Toda organização deve considerar o IG1 como ponto de partida, conforme a orientação do CIS.
- A seleção do grupo deve considerar sensibilidade dos dados, serviços críticos, exposição a ameaças, obrigações legais e contratuais, tolerância do negócio, tecnologia, pessoal e experiência.

- Um Grupo de Implementação é um mecanismo de priorização; não autoriza ignorar riscos materiais ou requisitos obrigatórios.
- Documente acréscimos, sequência, exceções, aceitação de risco, responsáveis e datas.
- Utilize o CIS Controls Navigator oficial para filtrar as Salvaguardas v8.1 e consultar os mapeamentos.

3. Governança, escopo e responsabilidades

A base de gestão necessária para operar as Salvaguardas de maneira consistente.

- Defina objetivos de negócio, serviços críticos, dados sensíveis, obrigações legais e contratuais, perfil de ameaças, tolerância ao risco e Grupo de Implementação selecionado.
- Mantenha inventários completos de ativos empresariais, software, dados, contas, sistemas de autenticação, infraestrutura de rede, registros, fornecedores, aplicações e recursos de recuperação.
- Designe um responsável principal para cada Salvaguarda e responsáveis operacionais para cada plataforma ou processo afetado.
- Defina escopo, aplicabilidade, dependências, responsabilidades de prestadores de serviços, exceções permitidas, autoridade de aprovação e gatilhos de revisão.
- Planeje orçamento, pessoas, competências, tecnologia, tempo e gestão de mudanças.
- Defina métricas e relatórios antes da implementação para tornar visíveis a cobertura e as falhas.
- Opere um ciclo de governança: priorizar, implementar, medir, corrigir, testar novamente e melhorar.

Função	Decisão ou responsabilidade
Patrocinador executivo	Direção, tolerância ao risco, orçamento, escalonamento e responsabilidade final.
Responsável pelo Controle	Desenho da Salvaguarda, escopo, procedimento, medição, exceções e melhoria.
Responsável pelo ativo ou serviço	Inventário preciso, uso aprovado, configuração, impacto de negócio e remediação.
Operações de segurança	Monitoramento, alertas, investigação, resposta e evidências.
TI e engenharia	Implementação, gestão de mudanças, correções, configuração e recuperação.
GRC ou analista	Mapeamento, evidências, medição, achados, acompanhamento de ações e relatórios.
Auditoria interna ou avaliador	Critérios objetivos, testes, limitações e conclusões.
Prestador de serviços	Controles contratados, evidências, incidentes,

Função	Decisão ou responsabilidade
	mudanças e apoio à saída.

4. Medição com a especificação de avaliação do CIS

Um método repetível para determinar se as Salvaguardas estão implementadas.

Figura 3. Estrutura de medição das Salvaguardas CIS

Elemento	Pergunta
Metadados da Salvaguarda	Qual é a Salvaguarda exata, a classe de ativo, a função de segurança e o IG?
Dependências	Quais outras Salvaguardas ou populações devem existir primeiro?
Premissas	Qual condição aceita afeta a medição?
Entradas	Quais dados completos e confiáveis são necessários?
Operações	Qual análise deve ser realizada sobre as entradas?
Medidas	Quais contagens, listas, datas, configurações ou resultados são produzidos?
Métricas	Como as medidas são calculadas e interpretadas?
Revisão de procedimentos	Existe um processo documentado e ele contém os elementos necessários?
• Defina com precisão a Salvaguarda e a população aplicável. • Obtenha as entradas necessárias e valide completude, precisão, atualidade, propriedade e confiabilidade da fonte. • Siga as operações oficiais de medição ou documente um método equivalente e confiável. • Preserve os cálculos das medidas e a população de exceções subjacente, não apenas uma porcentagem. • Avalie se a Salvaguarda está implementada e opera adequadamente. • Atribua correções para cobertura ausente, configuração inadequada, revisão atrasada, exceções ou dados não confiáveis. • Execute novos testes utilizando os mesmos critérios e a população atualizada. • Relate escopo, resultado, exceções, limitações, responsável, ação e data.	

5. Roteiro de implementação

Uma sequência prática que começa com inventários e termina com resiliência testada.

1. Selecione e documente o Grupo de Implementação inicial e os acréscimos necessários.
2. Construa e concilie as populações principais: ativos, software, dados, contas, sistemas de autenticação, redes, fornecedores, aplicações e registros.
3. Implemente as Salvaguardas do IG1 com responsáveis, procedimentos, métricas de cobertura, exceções e evidências.
4. Proteja identidades e configurações; gerencie vulnerabilidades, e-mail, navegadores, defesas contra malware, cópias de segurança e monitoramento essencial.
5. Exercite resposta a incidentes e recuperação antes de uma emergência real.
6. Meça cada Salvaguarda aplicável utilizando entradas confiáveis e operações repetíveis.
7. Corrija cobertura incompleta e falhas recorrentes; confirme as correções por meio de novos testes.
8. Expanda para IG2 ou IG3 conforme o risco, as obrigações, a maturidade e a exposição a ameaças.
9. Utilize mapeamentos oficiais para coordenar outras estruturas sem tratar o mapeamento como comprovação automática de conformidade.

Princípio de implementação: Um conjunto menor de Salvaguardas, com escopo completo, operação consistente, medição e melhoria contínua, é mais defensável do que uma lista extensa marcada como concluída sem evidências confiáveis.

6. Controle 1 — Inventário e controle de ativos empresariais

As 5 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Figura 4. Ciclo de inventário de ativos e software

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de inventário e controle de ativos empresariais.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
1.1	Estabelecer e manter um inventário detalhado de ativos empresariais	Manter um inventário completo, atualizado e com responsável definido.	Confirmar escopo, população, responsável, frequência, cobertura, exceções, correção e novo teste.	Inventário de ativos, responsáveis, estado de aprovação, descoberta ativa e passiva, registros DHCP/IPAM e tickets de ativos não autorizados.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
1.2	Tratar ativos não autorizados	Detectar, investigar e remover, isolar ou autorizar formalmente ativos não autorizados.	Verificar que alertas geram ações rastreáveis e tempestivas.	Alertas, tickets, registros de isolamento, autorizações e evidências de encerramento.
1.3	Utilizar uma ferramenta de descoberta ativa	Executar descoberta ativa para identificar ativos conectados e conciliar os resultados com o inventário.	Confirmar cobertura, programação, exclusões e conciliação.	Configuração de varredura, resultados, inventário atualizado e exceções aprovadas.
1.4	Utilizar registros DHCP para atualizar o inventário de ativos empresariais	Integrar registros DHCP ao processo de atualização e conciliação do inventário.	Verificar ingestão, frequência, cobertura e tratamento de divergências.	Registros DHCP, integrações, relatórios de conciliação e tickets.
1.5	Utilizar uma ferramenta de descoberta passiva de ativos	Monitorar tráfego ou telemetria para identificar ativos sem gerar varredura ativa.	Confirmar sensores, segmentos cobertos, alertas e conciliação.	Configuração de sensores, resultados, cobertura de rede e atualizações do inventário.

Consulte os CIS Controls v8.1 e a CIS Controls Assessment Specification oficiais para confirmar linguagem exata, classe de ativo, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão de procedimentos.

7. Controle 2 — Inventário e controle de ativos de software

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de inventário e controle de ativos de software.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
2.1	Estabelecer e manter um inventário de software	Manter um inventário autorizado, atualizado e com responsáveis definidos.	Confirmar escopo, responsável, frequência, cobertura e exceções.	Inventário, versões, responsáveis, estado de suporte e resultados de descoberta.
2.2	Assegurar que o software autorizado tenha suporte vigente	Identificar software sem suporte e atualizá-lo, substituí-lo ou tratá-lo por meio de exceção aprovada.	Verificar datas de fim de suporte e ações corretivas.	Inventário, boletins de fornecedores, planos de atualização e exceções.
2.3	Tratar software não autorizado	Detectar e remover, bloquear ou aprovar formalmente software não autorizado.	Confirmar que os achados geram ações rastreáveis.	Alertas, tickets, registros de desinstalação, bloqueios e aprovações.
2.4	Utilizar ferramentas automatizadas de inventário de software	Automatizar a detecção de software instalado e conciliá-la com o inventário autorizado.	Verificar cobertura, frequência e tratamento de divergências.	Configuração das ferramentas, resultados e relatórios de conciliação.
2.5	Criar uma lista de software autorizado	Permitir a execução apenas de software aprovado conforme o risco e a necessidade do negócio.	Confirmar política, cobertura, exceções e eventos de bloqueio.	Política de allowlisting, regras, exceções e registros de eventos.
2.6	Criar uma lista de bibliotecas autorizadas	Restringir bibliotecas e componentes carregados a versões aprovadas.	Verificar regras, cobertura e exceções.	Configuração, inventário de bibliotecas, eventos e aprovações.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
2.7	Criar uma lista de scripts autorizados	Restringir a execução de scripts aos aprovados e controlados.	Confirmar assinatura, regras, cobertura e exceções.	Repositório aprovado, assinaturas, regras de execução e eventos.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

8. Controle 3 — Proteção de dados

As 14 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Figura 5. Ciclo de vida da proteção de dados

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de proteção de dados.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
3.1	Estabelecer e manter um processo de gestão de dados	Definir como os dados são identificados, classificados, protegidos, retidos e eliminados.	Confirmar escopo, responsável, revisão e aplicação.	Política, procedimentos, responsáveis e registros de revisão.
3.2	Estabelecer e manter um inventário de dados	Manter inventário de conjuntos de dados, localização, responsável, sensibilidade e uso.	Verificar cobertura, atualidade e conciliação.	Inventário, catálogos, responsáveis e resultados de descoberta.
3.3	Configurar listas de controle de acesso a dados	Limitar o acesso a dados de acordo com a necessidade e a autorização.	Revisar permissões, funções, exceções e recertificações.	ACLs, funções, aprovações e revisões de acesso.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
3.4	Aplicar a retenção de dados	Reter dados durante o período aprovado e exigido.	Comparar regras, sistemas e resultados.	Cronograma de retenção, configurações e registros.
3.5	Eliminar dados de forma segura	Destruir ou apagar dados de modo verificável quando não forem mais necessários.	Confirmar método, cobertura e evidência de eliminação.	Certificados, registros, tickets e testes de apagamento.
3.6	Criptografar dados em dispositivos de usuários finais	Proteger dados armazenados em dispositivos por meio de criptografia gerenciada.	Verificar cobertura, chaves, exceções e estado.	Console de criptografia, inventário, políticas e exceções.
3.7	Estabelecer e manter um esquema de classificação de dados	Definir níveis de sensibilidade e regras de tratamento.	Confirmar critérios, aprovação, comunicação e uso.	Esquema, etiquetas, procedimentos e treinamento.
3.8	Documentar fluxos de dados	Manter diagramas e registros de como os dados são coletados, processados, armazenados e transferidos.	Verificar integridade, atualidade e responsáveis.	Diagramas, registros de tratamento e interfaces.
3.9	Criptografar dados em mídias removíveis	Exigir criptografia para dados armazenados em mídias removíveis.	Confirmar política, configuração e exceções.	Configuração, inventário de mídias e registros.
3.10	Criptografar dados sensíveis em trânsito	Proteger comunicações que transportam dados sensíveis.	Revisar protocolos, certificados, cobertura e exceções.	Configuração TLS/VPN, certificados e resultados de testes.
3.11	Criptografar	Proteger dados	Confirmar	Configuração,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	dados sensíveis em repouso	sensíveis armazenados em bancos, arquivos e cópias de segurança.	algoritmos, chaves, cobertura e exceções.	KMS/HSM, inventários e testes.
3.12	Segmentar o processamento e o armazenamento de dados de acordo com a sensibilidade	Separar ambientes e repositórios conforme a classificação e o risco.	Revisar arquitetura, regras e fluxos permitidos.	Diagramas, segmentação, regras e resultados de testes.
3.13	Implementar uma solução de prevenção contra perda de dados	Detectar e controlar transferências não autorizadas de dados sensíveis.	Verificar cobertura, regras, alertas, exceções e resposta.	Políticas DLP, eventos, tickets e métricas.
3.14	Registrar o acesso a dados sensíveis	Manter registros suficientes para identificar quem acessou dados sensíveis e quais ações foram realizadas.	Confirmar fontes, detalhamento, retenção e revisão.	Registros de acesso, SIEM, alertas e revisões.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

9. Controle 4 — Configuração segura de ativos empresariais e software

As 12 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de configuração segura de ativos empresariais e software.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
4.1	Estabelecer e manter um	Definir, aprovar, implementar e	Confirmar padrões,	Padrões, linhas de base,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	processo de configuração segura	revisar configurações seguras para ativos e software.	responsáveis, frequência, cobertura e exceções.	resultados de avaliação e exceções.
4.2	Estabelecer e manter um processo de configuração segura para a infraestrutura de rede	Aplicar linhas de base seguras a dispositivos e serviços de rede.	Revisar cobertura, mudanças, desvios e correções.	Configurações, backups, comparações e tickets.
4.3	Configurar o bloqueio automático de sessão em ativos empresariais	Bloquear sessões inativas após o período aprovado.	Verificar política, configuração e cobertura.	GPO/MDM, resultados de consulta e exceções.
4.4	Implementar e gerenciar um firewall em servidores	Habilitar e gerenciar regras de firewall em servidores.	Revisar cobertura, regras, mudanças e exceções.	Configuração, inventário, regras e registros.
4.5	Implementar e gerenciar um firewall em dispositivos de usuários finais	Habilitar e gerenciar o firewall local em endpoints.	Confirmar cobertura e estado centralizado.	Console, políticas e relatórios de conformidade.
4.6	Gerenciar de forma segura ativos empresariais e software	Utilizar protocolos e canais administrativos seguros.	Revisar métodos de administração, autenticação e registros.	Configuração, listas de administradores e registros.
4.7	Gerenciar contas padrão em ativos empresariais e software	Desabilitar, alterar ou controlar contas padrão.	Confirmar inventário, estado e exceções.	Resultados de varredura, configuração e tickets.
4.8	Desinstalar ou desabilitar serviços desnecessários	Reduzir a superfície de ataque removendo serviços não	Comparar linhas de base, serviços ativos e exceções.	Inventário de serviços, configuração e aprovações.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		exigidos.		
4.9	Configurar servidores DNS confiáveis em ativos empresariais	Forçar o uso de resolvedores DNS aprovados.	Verificar configuração, cobertura e desvios.	GPO/MDM, configuração de rede e registros DNS.
4.10	Aplicar bloqueio automático do dispositivo em equipamentos portáteis de usuários finais	Bloquear dispositivos portáteis após inatividade ou tentativas malsucedidas.	Confirmar política, configuração e cobertura.	MDM, políticas e relatórios.
4.11	Aplicar capacidade de apagamento remoto em dispositivos portáteis de usuários finais	Permitir apagamento remoto gerenciado quando o risco exigir.	Verificar cobertura, autorização e testes.	Console MDM, procedimentos e registros de testes.
4.12	Separar espaços de trabalho empresariais em dispositivos móveis de usuários finais	Separar dados e aplicações empresariais dos pessoais.	Revisar perfis, políticas e cobertura.	Configuração MDM/MAM, inventário e relatórios.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

10. Controle 5 — Gestão de contas

As 6 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de contas.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
5.1	Estabelecer e manter um inventário de contas	Manter uma população completa de contas com	Confirmar cobertura, atualidade, responsáveis e	Inventários, diretórios, relatórios e revisões.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		responsável, tipo, estado e datas relevantes.	conciliação.	
5.2	Utilizar senhas exclusivas	Impedir a reutilização de senhas entre contas gerenciadas.	Revisar política, configuração, exceções e testes.	Política, configuração de identidade e resultados de auditoria.
5.3	Desabilitar contas inativas	Desabilitar oportunamente contas que ultrapassem o período de inatividade aprovado.	Confirmar limite, execução, exceções e acompanhamento.	Relatórios, tickets, registros e aprovações.
5.4	Restringir privilégios administrativos a contas administrativas dedicadas	Separar atividades administrativas das contas de uso normal.	Revisar população, privilégios, uso e exceções.	Diretórios, grupos privilegiados, PAM e registros de atividade.
5.5	Estabelecer e manter um inventário de contas de serviço	Manter responsável, finalidade, dependências, credenciais e revisão para cada conta de serviço.	Confirmar cobertura, rotação, uso e exceções.	Inventário, cofre de segredos, registros de rotação e revisões.
5.6	Centralizar a gestão de contas	Utilizar sistemas centrais de identidade para criar, alterar, desabilitar e revisar contas.	Verificar integrações, cobertura, processos e divergências.	Diretórios, IAM, fluxos de provisionamento e relatórios de conciliação.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

11. Controle 6 — Gestão do controle de acesso

As 8 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Figura 6. Ciclo de vida de identidade e acesso

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão do controle de acesso.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
6.1	Estabelecer um processo de concessão de acesso	Autorizar e provisionar acesso com base em necessidade, função e aprovação documentada.	Confirmar escopo, população, aprovadores, segregação de funções, prazo e exceções.	Solicitações, aprovações, registros de provisionamento, funções e revisões.
6.2	Estabelecer um processo de revogação de acesso	Remover ou ajustar acessos quando pessoas mudam de função, saem ou deixam de necessitar deles.	Verificar tempestividade, cobertura, integrações e exceções.	Tickets, registros de desligamento, relatórios de revogação e conciliações.
6.3	Exigir MFA para aplicações expostas externamente	Proteger aplicações acessíveis pela internet com autenticação multifator.	Confirmar cobertura por aplicação, usuários, métodos permitidos e exceções.	Configurações de identidade, relatórios de MFA, inventário de aplicações e exceções.
6.4	Exigir MFA para acesso remoto à rede	Proteger VPN e outros métodos de acesso remoto com MFA.	Verificar cobertura, protocolos, grupos e exceções.	Configuração VPN, políticas de identidade, registros e testes.
6.5	Exigir MFA para acesso administrativo	Exigir MFA para contas e operações privilegiadas.	Confirmar população administrativa, plataformas cobertas e métodos resistentes a fraude quando aplicável.	PAM, diretórios, políticas, registros de autenticação e exceções.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
6.6	Estabelecer e manter um inventário de sistemas de autenticação e autorização	Manter uma lista atualizada dos sistemas que autenticam usuários ou concedem permissões.	Verificar responsável, finalidade, integrações, criticidade e revisão.	Inventário, diagramas, responsáveis, integrações e revisões.
6.7	Centralizar o controle de acesso	Utilizar serviços centrais de identidade e autorização sempre que viável.	Confirmar cobertura, integrações, contas locais residuais e tratamento de divergências.	Diretórios, IAM, SSO, relatórios de integração e exceções.
6.8	Definir e manter controle de acesso baseado em funções	Associar permissões a funções aprovadas e revisar sua adequação.	Verificar catálogo de funções, proprietários, conflitos, revisões e exceções.	Matriz de funções, aprovações, recertificações e relatórios de conflito.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

12. Controle 7 — Gestão contínua de vulnerabilidades

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Figura 7. Gestão contínua de vulnerabilidades

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão contínua de vulnerabilidades.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
7.1	Estabelecer e manter um processo de gestão de vulnerabilidades	Definir escopo, responsáveis, fontes, frequência, priorização,	Confirmar cobertura, critérios, exceções e	Política, procedimento, inventários, métricas e atas

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		correção e novos testes.	governança.	de revisão.
7.2	Estabelecer e manter um processo de remediação	Priorizar e corrigir vulnerabilidades conforme risco e prazo aprovado.	Verificar SLAs, responsáveis, exceções, compensações e escalonamento.	Tickets, planos, exceções, aprovações e métricas.
7.3	Realizar gestão automatizada de correções do sistema operacional	Automatizar a distribuição e verificação de correções de sistemas operacionais.	Confirmar cobertura, anéis de teste, falhas, prazos e exceções.	Console de patch, relatórios, registros de mudança e tickets.
7.4	Realizar gestão automatizada de correções de aplicações	Automatizar a atualização de aplicações e componentes gerenciados.	Verificar inventário, cobertura, versões, falhas e exceções.	Ferramentas de gestão, relatórios, inventário e registros de mudança.
7.5	Executar varreduras automatizadas de vulnerabilidades em ativos internos	Avaliar periodicamente ativos internos, preferencialmente com autenticação.	Confirmar população, credenciais, frequência, exclusões e qualidade dos resultados.	Configurações de varredura, resultados, cobertura e exceções.
7.6	Executar varreduras automatizadas de vulnerabilidades em ativos expostos externamente	Avaliar ativos voltados à internet com frequência e escopo definidos.	Verificar inventário externo, cobertura, frequência, validação e exceções.	Inventário, resultados, relatórios de exposição e tickets.
7.7	Corrigir vulnerabilidades detectadas	Remediar ou tratar formalmente vulnerabilidades identificadas.	Confirmar prioridade, ação, prazo, evidência de correção e novo teste.	Tickets, alterações, exceções, rescans e evidências de encerramento.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

13. Controle 8 — Gestão de registros de auditoria

As 12 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão de registros de auditoria.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
8.1	Estabelecer e manter um processo de gestão de registros de auditoria	Definir fontes, requisitos, responsáveis, proteção, retenção e revisão de logs.	Confirmar escopo, inventário, padrões, exceções e atualização.	Política, procedimento, inventário de fontes e registros de revisão.
8.2	Coletar registros de auditoria	Habilitar e coletar eventos necessários nos sistemas aplicáveis.	Verificar cobertura, tipos de evento, falhas de coleta e exceções.	Configurações, amostras de logs, relatórios de ingestão e alertas.
8.3	Garantir armazenamento adequado dos registros de auditoria	Dimensionar e proteger armazenamento para evitar perda ou alteração indevida.	Confirmar capacidade, integridade, acesso, monitoramento e exceções.	Configuração, métricas de capacidade, controles de acesso e alertas.
8.4	Padronizar a sincronização de tempo	Sincronizar relógios com fontes aprovadas para permitir correlação confiável.	Verificar fontes, cobertura, deriva, alertas e exceções.	Configuração NTP, inventário, métricas e registros.
8.5	Coletar registros detalhados de auditoria	Registrar detalhes suficientes para investigação e responsabilização.	Confirmar campos, identidade, ação, objeto, resultado, origem e horário.	Configurações, amostras de eventos e validações.
8.6	Coletar registros de consultas DNS	Registrar consultas DNS relevantes para	Verificar resolvedores cobertos,	Logs DNS, configuração, SIEM e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		detecção e investigação.	campos, retenção e ingestão.	relatórios de cobertura.
8.7	Coletar registros de solicitações de URL	Registrar solicitações web relevantes em proxies, gateways ou serviços equivalentes.	Confirmar fontes, campos, privacidade, retenção e ingestão.	Logs de proxy, gateway, SIEM e testes.
8.8	Coletar registros de linha de comando	Registrar execução de comandos onde aplicável ao risco.	Verificar plataformas, usuários, integridade, privacidade e cobertura.	Políticas de auditoria, EDR, amostras de eventos e exceções.
8.9	Centralizar registros de auditoria	Enviar logs relevantes a uma plataforma central protegida.	Confirmar fontes, disponibilidade, atrasos, falhas e exceções.	SIEM, coletores, painéis de ingestão e alertas.
8.10	Reter registros de auditoria	Manter logs pelo período definido por risco e obrigações.	Verificar política, configuração, armazenamento e descarte.	Política de retenção, configurações, testes e relatórios.
8.11	Realizar revisões de registros de auditoria	Revisar eventos e alertas com frequência e responsabilidade definidas.	Confirmar casos de uso, responsáveis, frequência, escalonamento e evidências.	Procedimentos, tickets, investigações, métricas e atas.
8.12	Coletar registros de prestadores de serviços	Obter logs necessários de serviços terceirizados e em nuvem.	Verificar contratos, fontes, acesso, retenção, integração e lacunas.	Contratos, configurações de exportação, logs, SIEM e exceções.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

14. Controle 9 — Proteções de e-mail e navegador web

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de proteção de e-mail e navegador web.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
9.1	Garantir o uso apenas de navegadores e clientes de e-mail com suporte vigente	Permitir somente versões suportadas e atualizadas.	Confirmar inventário, versões, bloqueios, exceções e atualização.	Inventário, políticas, relatórios de versão e tickets.
9.2	Utilizar serviços de filtragem DNS	Bloquear domínios maliciosos ou não autorizados por meio de resolvedores aprovados.	Verificar cobertura, políticas, bypass, eventos e exceções.	Configuração DNS, políticas, logs e relatórios.
9.3	Manter e aplicar filtros de URL baseados em rede	Controlar acesso a categorias e destinos web conforme política.	Confirmar cobertura, regras, atualização, eventos e exceções.	Gateway web, proxy, políticas, logs e tickets.
9.4	Restringir extensões desnecessárias ou não autorizadas de navegadores e clientes de e-mail	Permitir somente extensões aprovadas e necessárias.	Verificar listas permitidas, aplicação, eventos e exceções.	GPO/MDM, catálogo aprovado, relatórios e tickets.
9.5	Implementar DMARC	Configurar SPF, DKIM e política DMARC apropriada para domínios de e-mail.	Confirmar cobertura de domínios, alinhamento, política, relatórios e exceções.	Registros DNS, relatórios DMARC, inventário de domínios e mudanças.
9.6	Bloquear tipos	Impedir anexos	Verificar regras,	Políticas de

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	de arquivo desnecessários	e downloads de tipos de arquivo não necessários ou de alto risco.	cobertura, quarentena, eventos e exceções.	gateway, registros, amostras e aprovações.
9.7	Implantar e manter proteção antimalware em servidores de e-mail	Verificar mensagens e anexos com mecanismos atualizados.	Confirmar cobertura, atualização, detecção, quarentena e resposta.	Configuração, relatórios, alertas, tickets e métricas.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

15. Controle 10 — Defesas contra malware

As 7 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de defesa contra malware.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
10.1	Implantar e manter software antimalware	Proteger ativos aplicáveis com solução antimalware gerenciada.	Confirmar cobertura, estado, políticas, alertas e exceções.	Console, inventário, relatórios de cobertura e tickets.
10.2	Configurar atualizações automáticas de assinaturas antimalware	Atualizar automaticamente e mecanismos, assinaturas e inteligência.	Verificar frequência, falhas, cobertura e exceções.	Configuração, relatórios de atualização e alertas.
10.3	Desabilitar execução automática e reprodução automática em mídias removíveis	Impedir execução automática de conteúdo de mídias removíveis.	Confirmar política, plataformas, cobertura e exceções.	GPO/MDM, configuração, testes e relatórios.
10.4	Configurar	Verificar mídias	Confirmar	Configuração,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	varredura antimalware automática de mídias removíveis	removíveis antes ou durante o uso.	política, eventos, bloqueios, cobertura e exceções.	logs, alertas e testes.
10.5	Habilitar recursos antiexploração	Ativar proteções contra exploração de memória e comportamento malicioso.	Verificar plataformas, políticas, compatibilidade, eventos e exceções.	EDR, políticas, relatórios e testes.
10.6	Gerenciar software antimalware de forma centralizada	Administrar políticas, atualizações, alertas e resposta em console central.	Confirmar cobertura, acesso administrativo, monitoramento e exceções.	Console, funções, políticas, alertas e métricas.
10.7	Utilizar software antimalware baseado em comportamento	Detectar atividades suspeitas além de assinaturas conhecidas.	Verificar cobertura, regras, alertas, investigação e ajuste.	EDR, eventos, casos de investigação, tickets e métricas.

Consulte os recursos oficiais do CIS para confirmar a linguagem exata e os critérios de avaliação.

16. Controle 11 — Recuperação de dados

As 5 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de recuperação de dados.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
11.1	Estabelecer e manter um processo de recuperação de dados	Definir responsabilidades, escopo, prioridades, dependências, objetivos e procedimentos	Confirmar aprovação, responsáveis, cobertura, revisão e alinhamento com	Política, plano de recuperação, inventário de sistemas, RTO/RPO, responsáveis e registros de

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		para recuperar dados e serviços.	necessidades de negócio.	revisão.
11.2	Executar backups automatizados	Realizar cópias de segurança de dados e configurações conforme uma programação aprovada.	Verificar cobertura, frequência, falhas, alertas e tratamento de exceções.	Configuração de backup, relatórios de execução, alertas, tickets e métricas de sucesso.
11.3	Proteger os dados de recuperação	Proteger backups contra acesso, alteração, exclusão e criptografia não autorizados.	Revisar acesso, criptografia, imutabilidade, segregação e monitoramento.	ACLs, KMS, armazenamento imutável, registros de acesso e alertas.
11.4	Estabelecer e manter uma instância isolada de dados de recuperação	Manter pelo menos uma cópia de recuperação separada do ambiente de produção.	Confirmar isolamento lógico ou físico, credenciais separadas e resistência a ransomware.	Diagramas, configuração, inventário de cópias isoladas e testes de acesso.
11.5	Testar a recuperação de dados	Executar testes periódicos de restauração e confirmar integridade, tempo e completude.	Comparar resultados com critérios aprovados e verificar correções por novo teste.	Planos de teste, resultados de restauração, evidências de integridade, achados e retestes.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

17. Controle 12 — Gestão da infraestrutura de rede

As 8 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de gestão da infraestrutura de rede.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
12.1	Assegurar que a infraestrutura de rede esteja atualizada	Manter hardware, software e serviços de rede em versões suportadas e aprovadas.	Verificar inventário, versões, fim de suporte, exceções e planos de atualização.	Inventário, matrizes de suporte, configurações, tickets e exceções.
12.2	Estabelecer e manter uma arquitetura de rede segura	Definir zonas, fluxos, confiança, segmentação e controles de acesso conforme o risco.	Revisar arquitetura, aprovações, mudanças, fluxos permitidos e testes.	Diagramas, padrões, regras, análises de fluxo e resultados de testes.
12.3	Gerenciar com segurança a infraestrutura de rede	Utilizar canais, protocolos, autenticação e estações administrativas seguras.	Confirmar métodos administrativos, MFA, registros e restrições de origem.	Configuração, listas de administradores, bastions, PAM e registros.
12.4	Estabelecer e manter diagramas de arquitetura	Manter diagramas atuais da infraestrutura, conexões, zonas e dependências.	Verificar abrangência, responsáveis, revisão e conciliação com a configuração real.	Diagramas, CMDB, revisões e tickets de atualização.
12.5	Centralizar autenticação, autorização e auditoria de rede	Utilizar serviços centrais para identidade administrativa e registro de atividades.	Verificar cobertura, integrações, disponibilidade, contas locais e exceções.	RADIUS/TACACS+, diretórios, logs, inventário e exceções.
12.6	Utilizar protocolos seguros de gestão e comunicação de rede	Desabilitar protocolos inseguros e utilizar alternativas criptografadas e autenticadas.	Revisar configuração, cobertura, certificados e desvios.	Configurações SSH, HTTPS, SNMPv3, VPN, certificados e resultados de varredura.
12.7	Assegurar que dispositivos	Exigir canais seguros e	Confirmar cobertura, MFA,	Configuração VPN, AAA,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
12.8	remotos utilizem VPN e AAA corporativo	autenticação corporativa para acesso remoto à rede.	políticas, registros e exceções.	relatórios de conexão, políticas e tickets.
	Manter recursos computacionais dedicados para trabalho administrativo	Separar atividades administrativas de navegação, e-mail e uso comum.	Verificar população, configuração, uso, monitoramento e exceções.	Inventário de estações administrativas, políticas, registros e controles de acesso.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

18. Controle 13 — Monitoramento e defesa da rede

As 11 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Figura 8. Fluxo de monitoramento até resposta

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de monitoramento e defesa da rede.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
13.1	Centralizar alertas de eventos de segurança	Reunir alertas relevantes em uma plataforma ou processo central de triagem.	Verificar fontes, cobertura, roteamento, prioridade e tratamento.	SIEM, integrações, filas, tickets, métricas e procedimentos.
13.2	Implantar uma solução de detecção de intrusão baseada em host	Detectar comportamento s e eventos suspeitos em endpoints e servidores.	Confirmar cobertura, estado dos agentes, regras, alertas e exceções.	Console EDR/HIDS, inventário, políticas, alertas e tickets.
13.3	Implantar uma solução de detecção de	Monitorar tráfego de rede para identificar	Verificar sensores, segmentos,	Configuração NIDS, diagramas,

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	intrusão de rede	atividades suspeitas.	regras, visibilidade e tratamento de alertas.	cobertura, eventos e investigações.
13.4	Realizar filtragem de tráfego entre segmentos de rede	Permitir somente fluxos necessários e aprovados entre zonas.	Revisar regras, justificativas, recertificação, mudanças e testes.	Regras de firewall, matrizes de fluxo, aprovações e resultados de testes.
13.5	Gerenciar o controle de acesso para ativos remotos	Aplicar identidade, postura, autorização e monitoramento ao acesso remoto.	Confirmar população, políticas, MFA, restrições e exceções.	VPN/ZTNA, MDM, IAM, registros e relatórios.
13.6	Coletar registros de fluxo de tráfego de rede	Manter telemetria suficiente para analisar comunicações e anomalias.	Verificar fontes, campos, retenção, sincronização e uso em investigações.	NetFlow/IPFIX, registros, retenção e casos de investigação.
13.7	Implantar uma solução de prevenção de intrusão baseada em host	Bloquear ou conter atividades maliciosas em endpoints quando apropriado.	Confirmar modo de prevenção, políticas, cobertura, exceções e testes.	Console HIPS/EDR, políticas, eventos bloqueados e testes.
13.8	Implantar uma solução de prevenção de intrusão de rede	Bloquear tráfego malicioso conhecido conforme regras aprovadas.	Verificar posicionamento, modo, regras, exceções e impactos.	Configuração NIPS, alterações, eventos, exceções e testes.
13.9	Implantar controle de acesso em nível de porta	Controlar dispositivos e identidades que podem se conectar à rede.	Confirmar cobertura, autenticação, quarentena, exceções e falhas.	NAC/802.1X, inventário, políticas, registros e tickets.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
13.10	Realizar filtragem na camada de aplicação	Restringir tráfego por aplicação, conteúdo ou contexto conforme o risco.	Revisar políticas, cobertura, exceções, alertas e mudanças.	Proxy, NGFW, WAF, regras, eventos e aprovações.
13.11	Ajustar limiares de alertas de eventos de segurança	Afinar regras para reduzir ruído sem perder detecções relevantes.	Confirmar responsáveis, critérios, histórico, testes e revisão periódica.	Registros de tuning, métricas, casos de teste e aprovações.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

19. Controle 14 — Conscientização e capacitação em segurança

As 9 Salvaguardas, seu significado claro, o enfoque de verificação e exemplos de evidências.

Finalidade do Controle: Fortalecer a organização por meio da implementação e medição das Salvaguardas de conscientização e capacitação em segurança.

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
14.1	Estabelecer e manter um programa de conscientização em segurança	Definir conteúdo, público, frequência, responsabilidades, avaliação e melhoria.	Verificar aprovação, cobertura, atualidade, conclusão e exceções.	Programa, currículo, população, registros de conclusão e métricas.
14.2	Capacitar a força de trabalho para reconhecer ataques de engenharia social	Ensinar identificação e comunicação de phishing, fraude, pretexting e manipulação.	Confirmar conteúdo, frequência, simulações, resultados e acompanhamento.	Materiais, simulações, relatórios, tickets e ações corretivas.
14.3	Capacitar a força de trabalho em boas práticas de	Ensinar uso de MFA, senhas exclusivas,	Verificar conteúdo, população,	Treinamento, registros, avaliações e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
	autenticação	gestores de senhas e proteção de credenciais.	conclusão e avaliação.	campanhas.
14.4	Capacitar a força de trabalho em boas práticas de tratamento de dados	Ensinar classificação, compartilhamento, armazenamento, retenção e descarte seguros.	Confirmar alinhamento com políticas e cobertura de funções relevantes.	Materiais, políticas, registros de conclusão e avaliações.
14.5	Capacitar a força de trabalho sobre causas de exposição não intencional de dados	Explicar erros comuns, destinatários incorretos, links públicos, dispositivos e serviços não aprovados.	Verificar exemplos, público, conclusão e resultados.	Conteúdo, campanhas, registros e incidentes correlacionados.
14.6	Capacitar a força de trabalho para reconhecer e comunicar incidentes de segurança	Ensinar sinais, canais, urgência e informações necessárias para reporte.	Confirmar canais, exercícios, conhecimento e acompanhamento.	Materiais, contatos, exercícios, tickets e métricas de reporte.
14.7	Capacitar a força de trabalho para identificar e comunicar atualizações de segurança ausentes	Ensinar como reconhecer sistemas desatualizados e reportar desvios.	Verificar conteúdo, população e integração com suporte.	Treinamento, procedimentos, tickets e exemplos.
14.8	Capacitar a força de trabalho sobre riscos de redes inseguras	Ensinar uso seguro de Wi-Fi, VPN, hotspots e redes públicas.	Confirmar cobertura de trabalhadores remotos e viajantes.	Materiais, políticas, registros e avaliações.
14.9	Conduzir conscientização e capacitação específicas por função	Fornecer treinamento adicional para funções com riscos ou	Verificar matriz de funções, conteúdo, conclusão, competência e	Matriz, cursos, avaliações, certificações internas e

ID	Salvaguarda	Significado claro	Enfoque de verificação	Exemplos de evidências
		privilégios específicos.	atualização.	registros.

Consulte os recursos oficiais do CIS para confirmar a linguagem e os critérios de avaliação.

20. Controle 15 — Gestão de Prestadores de Serviços

- Todas as 7 Salvaguardas, significado simples, foco de verificação e evidência de exemplo.*

. ** Finalidade do controle: ** Reforçar a empresa através da implementação e medição de salvaguardas para a gestão dos prestadores de serviços. □

□ 15.1 □ Estabeleça e mantenha um Inventário de Prestadores de Serviços □ Coloque em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter um Inventário de Prestadores de Serviços, em seguida, verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento • 15.2 • Estabelecer e manter uma política de gerenciamento de provedores de serviços • Colocar em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter uma política de gerenciamento de provedores de serviços e, em seguida, verificar cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento □ 15.3 □ Classifique prestadores de serviços Coloque em prática um processo repetível, de propriedade ou controle técnico para classificar os provedores de serviços, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento □ 15.4 □ Garanta que os contratos de prestador de serviços incluam requisitos de segurança □ Coloque em prática um processo repetível, de propriedade ou controle técnico para garantir que os contratos de prestador de serviços incluam requisitos de segurança, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento □ 15.5 □ Avaliar Prestadores de Serviços □ Coloque em prática um processo repetível, de propriedade ou controle técnico para avaliar Prestadores de Serviços, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento Monitorar provedores de serviços Coloque em prática um processo repetível, de propriedade ou

controle técnico para monitorar provedores de serviços, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento 15.7 Prestadores de serviços de desmantelamento seguros Coloque em prática um processo repetível, de propriedade ou controle técnico para os provedores de serviços de desactivação com segurança e, em seguida, verifique a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Inventário, classificações, política, contratos, avaliações, acompanhamento, incidentes e provas de desmantelamento

Use o guia oficial de Controles CIS v8.1 e Especificações de Avaliação de Controles para linguagem de Salvaguarda exata, classe de ativos, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão processual.

21. Controle 16 — Segurança de Software de Aplicação

- Todas as 14 Salvaguardas, significado simples, foco de verificação e evidência de exemplo.*

. ** Finalidade do controle: ** Fortaleça a empresa implementando e medindo salvaguardas para segurança de software de aplicação. □

* * * * *

□ 16.1 □ Estabelecer e manter um processo seguro de desenvolvimento de aplicativos □ Colocar em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter um processo seguro de desenvolvimento de aplicativos, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Criar e Manter um Processo para Aceitar e Endereçar Vulnerabilidades de Software .Coloque em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter um Processo para Aceitar e Endereçar Vulnerabilidades de Software, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Realizar análise de causas de raiz em vulnerabilidades de segurança Colocar um processo repetível, de propriedade ou controle técnico para realizar análise de causas de raiz em vulnerabilidades de segurança, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça □ 16.4 Criar e Gerenciar um Inventário de Componentes de Software de Terceiros □ Coloque em prática um processo repetível, de propriedade ou controle técnico para estabelecer e gerenciar um Inventário de Componentes de Software de Terceiros, em seguida, verifique a cobertura e

exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Use componentes de software de terceiros atualizados e confiáveis Coloque em prática um processo repetível, de propriedade ou controle técnico para usar Componentes de Software Up-to-Date e Trusted Third-Party, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça □ 16.6 □ Estabeleça um Sistema de Avaliação de Severidade e um Processo para Vulnerabilidades de Aplicações □ Coloque em prática um processo repetível, de propriedade ou controle técnico para estabelecer um Sistema de Avaliação de Severidade e Processo para Vulnerabilidades de Aplicações, em seguida, verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Use Modelos de Endurecimento Padrão para Infraestrutura de Aplicação □ Coloque em prática um processo repetível, de propriedade ou controle técnico para usar Modelos de Endurecimento Padrão para Infraestrutura de Aplicação, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça 16,8 Sistemas de Produção e Não Produção Separados Coloque em prática um processo repetível, de propriedade ou controle técnico para separar sistemas de produção e não-produção, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Os desenvolvedores de trens em Segurança de Aplicação e Codificação Segura . Coloque um processo repetível, de propriedade ou controle técnico para treinar desenvolvedores em Segurança de Aplicação e Codificação Segura, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Aplique Princípios de Design Seguro em Arquiteturas de Aplicação .Coloque em prática um processo repetível, de propriedade ou controle técnico para aplicar Princípios de Design Seguro em Arquiteturas de Aplicação e, em seguida, verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça Use Módulos ou Serviços Vetted para Componentes de Segurança de Aplicações □ Coloque em prática um processo repetível, de propriedade ou controle técnico para usar Módulos ou Serviços Vetted para Componentes de Segurança de Aplicações, em seguida, verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça 6.12 Implementar verificações de segurança de nível de código Coloque em prática um processo repetível, de propriedade ou controle técnico para

implementar verificações de segurança de nível de código, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça

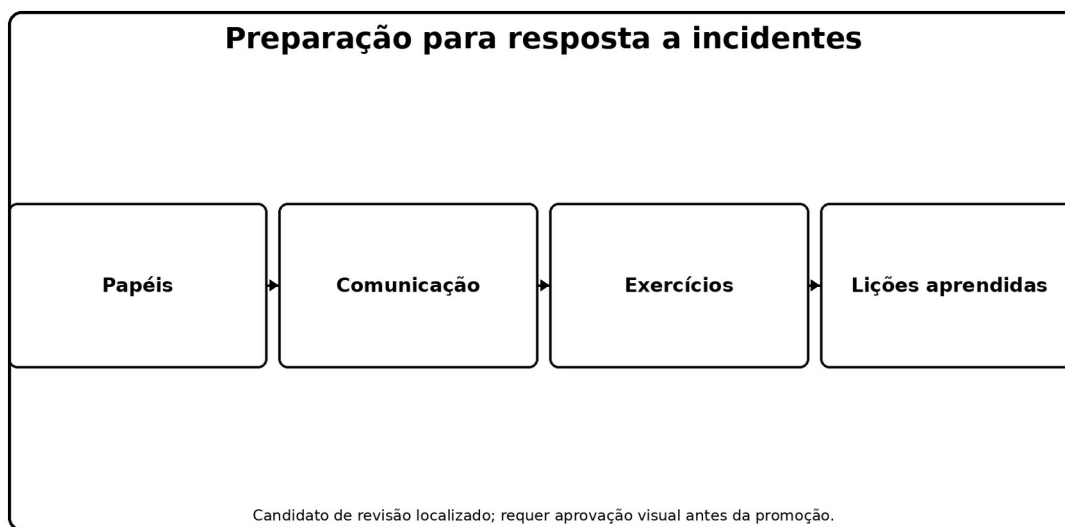
Teste de penetração de aplicação de condução Coloque em prática um processo repetível, de propriedade ou controle técnico para realizar o Teste de Penetração de Aplicação, em seguida, verifique a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça

16.14 • Conduzir a Modelação de Ameaças • Coloque no lugar um processo repetível, de propriedade ou controle técnico para conduzir a Modelação de Ameaças, em seguida, verifique a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. SDLC seguro, processo de divulgação, causa raiz, inventário de componentes, severidade, endurecimento, treinamento, testes e modelos de ameaça

Use o guia oficial de Controles CIS v8.1 e Especificações de Avaliação de Controles para linguagem de Salvaguarda exata, classe de ativos, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão processual.

22. Controle 17 — Gestão de Respostas a Incidentes

- Todas as 9 Salvaguardas, significado simples, foco de verificação e evidência de exemplo.*



Preparados papéis, relatórios, comunicação, exercícios e comentários reduzem o impacto incidente.

Figura 9. Disponibilidade para resposta ao incidente

. ** Finalidade do controle: ** Reforçar a empresa através da implementação e medição de salvaguardas para a gestão da resposta a incidentes. □

* * * * *

* * * * *

□ 17.1 □ Designar Pessoal para Gerenciar o Tratamento de Incidentes □ Coloque em prática um processo repetível, de propriedade ou controle técnico para designar Pessoal para Gerenciar o Tratamento de Incidentes e, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares • 17,2 • Mantenha as informações de contato para os incidentes de segurança de relatórios • Coloque em prática um processo repetível, de propriedade ou controle técnico para manter as informações de contato para os incidentes de segurança de relatórios e, em seguida, verifique a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares Manter um Processo Empresarial para Incidentes de Relato . Coloque em prática um processo repetível, de propriedade ou controle técnico para manter um Processo Empresarial para Incidentes de Relato, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares □ 17.4 □ Estabelecer e manter um Processo de Resposta a Incidentes □ Colocar em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter um Processo de Resposta a Incidentes, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares Atribuir funções-chave e responsabilidades .Coloque no lugar um processo repetível, de propriedade ou controle técnico para atribuir funções-chave e responsabilidades, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares Define mecanismos para comunicação durante a resposta ao incidente Coloque em prática um processo repetível, de propriedade ou controle técnico para definir Mecanismos de Comunicação Durante a Resposta a Incidentes, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares Exercícios de resposta de incidentes de rotina Coloque em prática um processo repetível, de propriedade ou controle técnico para realizar exercícios de resposta a incidentes de rotina, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares 17.8 Comentários Pós-Incidentes Coloque em prática um processo repetível, de propriedade ou controle técnico para realizar Revisões Pós-Incidentes, em seguida, verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios,

planos, funções, comunicações, exercícios, revisões e limiares □ 17.9 □ Estabelecer e Manter Limiares de Incidente de Segurança □ Colocar um processo repetível, de propriedade ou controle técnico para estabelecer e manter Limiares de Incidente de Segurança, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. Líderes incidentes, contatos, relatórios, planos, funções, comunicações, exercícios, revisões e limiares

Use o guia oficial de Controles CIS v8.1 e Especificações de Avaliação de Controles para linguagem de Salvaguarda exata, classe de ativos, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão processual.

23. Controle 18 — Testes de penetração

- Todas as 5 Salvaguardas, significado simples, foco de verificação e evidência de exemplo.*

. ** Finalidade do controle: ** Reforçar a empresa através da implementação e medição de salvaguardas para testes de penetração. □ □

Criar e Manter um Programa de Teste de Penetração. Coloque em prática um processo repetível, de propriedade ou controle técnico para estabelecer e manter um Programa de Teste de Penetração, então verifique cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. As regras aprovadas de engajamento, escopo, testadores qualificados, relatórios, remediação, reteste e evidência de validação . • 18.2 • Realizar Testes Periódicos de Penetração Externa Coloque um processo repetível, de propriedade ou controle técnico para realizar testes de penetração externa periódica, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. As regras aprovadas de engajamento, escopo, testadores qualificados, relatórios, remediação, reteste e evidência de validação . • 18,3 • Resultados do teste de penetração corretiva Coloque um processo repetível, de propriedade ou controle técnico no local para corrigir os resultados do teste de penetração, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. As regras aprovadas de engajamento, escopo, testadores qualificados, relatórios, remediação, reteste e evidência de validação . 18.4 Validar medidas de segurança Coloque em prática um processo repetível, de propriedade ou controle técnico para validar medidas de segurança, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade, implementação, frequência, cobertura, exceções, correção e reteste. As regras aprovadas de engajamento, escopo, testadores qualificados, relatórios, remediação, reteste e evidência de validação . Realizar testes de penetração interna periódica Coloque um processo repetível, de propriedade ou controle técnico para realizar testes de penetração interna periódica, em seguida, verificar a cobertura e exceções. Confirmar escopo definido, população, propriedade,

implementação, frequência, cobertura, exceções, correção e reteste. As regras aprovadas de engajamento, escopo, testadores qualificados, relatórios, remediação, reteste e evidência de validação .

Use o guia oficial de Controles CIS v8.1 e Especificações de Avaliação de Controles para linguagem de Salvaguarda exata, classe de ativos, função de segurança, Grupo de Implementação, dependências, entradas, operações, medidas, métricas e revisão processual.

24. Ferramentas de Código Aberto

- Links oficiais, inícios rápidos seguros, evidências e limitações.*

● Ferramenta Purpose Controles Possíveis

CIS Controls Navigator Seleccionar IGs e explorar mapeamentos oficiais CIS Controls Assessment Specification (Official Measurement Guideline) CIS-CAT Lite . Avaliação do valor de referência ☐ CISO Assistant ☐ Controles, riscos, evidências e achados * Wazuh * Monitoramento de endpoints, SIEM, FIM e alertas * 1, 4, 8, 10, 13, 17 * Osquery * Activo, software, conta e consultas de configuração * 1, 2, 4, 5, 8 • *Avaliação de configuração segura do OpenSCAP* Lynis * Auditoria de segurança Linux * 4, 7 *O Nmap O activo autorizado e a descoberta do serviço Edição da Comunidade Greenbone* Repositórios, imagens, dependências, segredos e IaC OWASP ZAP ☐ Testes de segurança da web autorizados ☐ Suricata ☐ Detecção de intrusão de rede e visibilidade de tráfego Keycloak, identidade, papéis, MFA, sessões e eventos DefectDojo * Encontrando ingestão, deduplicação, remediação e reteste * Velociraptor * Visibilidade e resposta de incidentes * 1, 8, 13, 17 *

Limitação crítica: ** Uma ferramenta pode suportar uma ou mais Salvaguardas, mas não pode escolher o GI da organização, definir tolerância ao risco, garantir cobertura completa, substituir procedimento e revisão humana, autorizar testes de penetração ou provar a conformidade de outro framework por si só. ☐ ☐

24,1 CIS Controla Navegador

Objetivo: Selecione IGs e explore mapeamentos oficiais. Projeto oficial: [CIS Controls Navigator](#)

Início rápido seguro: Escolha v8.1, selecione um Grupo de Implementação e mapeamento, reveja Salvaguardas e, em seguida, exporte a seleção autorizada.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.2 CIS Especificação de Avaliação de Controles

Objetivo: Orientação oficial de medição. Projecto oficial: [CIS Controls Assessment Specification](#)

Início rápido seguro: Abra uma Salvaguarda, identifique inputs e suposições, siga operações, calcule medidas e revisão do procedimento do documento.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24,3 CIS-CAT Lite

Objetivo: CIS selecionado Avaliação comparativa. Projecto oficial: [CIS-CAT Lite](#)

Início rápido seguro: Execute apenas em sistemas autorizados, escolha um benchmark e perfil disponíveis, preserve o relatório, valide as descobertas, corrija e reavalie.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.4 Assistente CISO

Objetivo: Controles, riscos, evidências e achados. Projeto oficial: [CISO Assistant](#)

Início rápido seguro: Crie um projeto abrangente, carregue um framework aplicável, atribua proprietários, anexe evidências, rastreie descobertas e reveja permissões.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.5 Wazuh

Objetivo: Monitoramento de pontos finais, SIEM, MIF e alertas. Projecto oficial: [Wazuh](#)

Início rápido e seguro: Inscreva-se em um endpoint de laboratório, desencadeie um evento seguro, confirme coleta e alerta, investigue e mantenha evidências de cobertura e resposta.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.6 Osquery

Finalidade: Asset, software, conta e consultas de configuração. Projeto oficial: [osquery](#)

Início rápido seguro: Execute consultas somente leitura em um laboratório, agendar consultas aprovadas, comparar resultados com inventários, plataforma de documentos e limites de cobertura.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.7 OpenSCAP

Objetivo: Avaliação da configuração segura do Linux. Projeto oficial: [OpenSCAP](#)

Início rápido seguro: Escolha um perfil apropriado, verifique um sistema de laboratório, valide resultados, exceções de documentos, corrija e reescane.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.8 Lynis

Objetivo: Auditoria de segurança Linux. Projeto oficial: [Lynis](#)

Início rápido seguro: Audite um host de laboratório, reveja os resultados contra o escopo e os padrões, atribua ações, corrija itens selecionados e reexecute.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.9 Nmap

Finalidade: Activo autorizado e descoberta de serviços. Projeto oficial: [Nmap](#)

Início rápido seguro: Use uma varredura limitada em intervalos escritos-autorizados, compare com inventário, investigue serviços desconhecidos e mantenha o escopo e evidência de comando.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.10 Greenbone Community Edition

Objetivo: Avaliação da vulnerabilidade. Projeto oficial: [Greenbone Community Edition](#)

Início rápido e seguro: Atualizar feeds, usar metas e credenciais autorizadas, validar cobertura de ativos, revisar descobertas, corrigir e reescapar.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.11 Trivy

Objetivo: Repositórios, imagens, dependências, segredos e IAC. Projeto oficial: [Trivy](#)

Início rápido e seguro: Analise um repositório de testes ou imagem, valide achados, confira exceções justificadas por documentos e reescane na tubulação.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.12 OWASP ZAP

Objetivo: Testes de segurança da web autorizados. Projecto oficial: [OWASP ZAP](#)

Início rápido seguro: Proxy uma aplicação de treinamento, rasteje passivamente, use a varredura ativa apenas com aprovação, valide achados, correto e reteste.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.13 Suricata

Objetivo: Detecção de intrusão de rede e visibilidade do tráfego. Projeto oficial: [Suricata](#)

Início rápido seguro: Use um sensor de laboratório, confirme interface e regras, gere tráfego de teste aprovado, valide alertas, afinar cuidadosamente e preservar o histórico de alterações.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.14 Keycloak

Objetivo: Identidade, papéis, MFA, sessões e eventos. Projeto oficial: [Keycloak](#)

Início rápido e seguro: Crie um reino de laboratório, papéis e MFA, teste casos de joiner-mover-leaver, reveja eventos e configuração de documentos e resultados.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.15 DefectDojo

Objetivo: Encontrar ingestão, deduplicação, remediação e reteste. Projeto oficial: [DefectDojo](#)

Início rápido seguro: Importar resultados seguros, validar deduplicação, atribuir proprietários e datas, anexar prova e fechar apenas após o reteste verificado.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

24.16 Velociraptor

Objetivo: Visibilidade do ponto final e resposta ao incidente. Projecto oficial: [Velociraptor](#)

Início rápido seguro: Implantar apenas em um laboratório autorizado isolado, coletar um artefato estreito, escopo de documentos e acesso, investigar resultados e remover dados do laboratório com segurança.

Evidências: escopo aprovado, versão, configuração, cobertura, dados fonte, resultados, revisão humana, exceção, remediação e reteste. Proteger o acesso administrativo e dados recolhidos.

25. Manual dos Controles CIS para gerentes

Perguntas, painel, propriedade e decisões os gerentes devem controlar.

1. O GI escolhido ainda é adequado para dados sensíveis, serviços críticos, exposição à ameaça, obrigações, escala e habilidades?
2. As populações centrais são completas, atuais, possuídas e reconciliadas com a descoberta independente?
3. Quais salvaguardas IG1 têm cobertura incompleta, revisão atrasada, dados de entrada não confiáveis, ou repetidas exceções?
4. O acesso administrativo, sistemas expostos externamente, software não suportado, vulnerabilidades críticas e falhas de recuperação aumentaram?
5. Os alertas resultam em investigação e resposta, ou apenas no volume do painel?
6. As responsabilidades dos prestadores de serviços, as provas, as obrigações em matéria de incidentes, os subcontratantes e os planos de saída estão entendidos?
7. Os testes de penetração e os exercícios são autorizados de forma segura, adequadamente explorados, realizados independentemente quando necessário, e seguidos através do reteste?
8. Que financiamento, pessoal, tempo de engenharia, ou decisão de negócios está bloqueando correção?

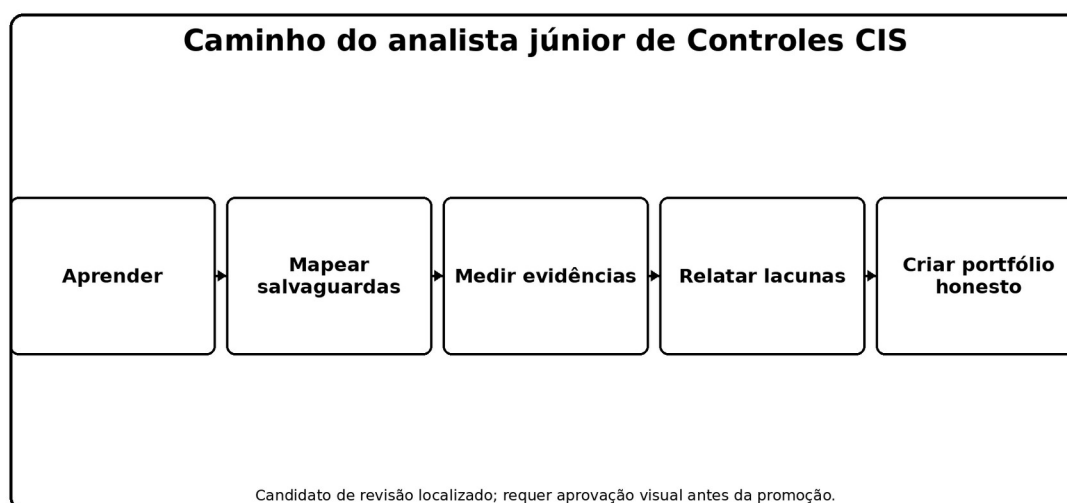
* * * * *

☐ GI e escopo ☐ Priorização, adições, exclusões e obrigações estão documentadas? Verde / Amarelo / Vermelho ☐ Inventários ☐ Os ativos, software, dados, contas, fornecedores, aplicativos e logs estão completos? Verde / Amarelo / Vermelho ☐ Proteção ☐ A configuração, o acesso, o patching, o email, o malware e os controles de dados estão funcionando? Verde /

Amarelo / Vermelho ☐ Detecção ☐ A cobertura de log e rede é completa e os alertas são revistos? Verde / Amarelo / Vermelho Recuperação , são protegidos backups e restaurações testados contra as necessidades dos negócios? Verde / Amarelo / Vermelho ☐ Resposta ☐ São atuais os papéis, contatos, limiares, exercícios e revisões? Verde / Amarelo / Vermelho ☐ Medição ☐ Os insumos são confiáveis e as populações de exceção corrigidas? Verde / Amarelo / Vermelho Assegura-te que os testes, as limitações, os resultados e os retestes são suportáveis? Verde / Amarelo / Vermelho

26. Guia de Carreira do Analista Júnior

Uma rota prática para controles, vulnerabilidade, garantia, GRC, e operações de segurança funcionam.



Learn the framework, map Safeguards, measure evidence, report gaps, and build an honest portfolio.

Figura 10. CIS Júnior Controla o caminho do analista

Analista de Controles de Segurança Júnior

GRC Analisador

Analista de Gestão de Vulnerabilidade

Analista de Garantia de Segurança

Analista de Operações de Segurança

Analisador de conformidade de TI

Analista de Riscos de Terceiros

Analista do Programa de Cibersegurança

26.1 Típico trabalho júnior

- Manter inventários de ativos, software, dados, contas, sistemas de rede, fornecedores, aplicações, descobertas e evidências.
- Recolher provas sem alterar os registos de origem e validar a completude da população.
- Mapa Salvaguardas para proprietários, sistemas, procedimentos, configuração, evidências, métricas, exceções e ações.
- Execute ferramentas autorizadas de descoberta, configuração, vulnerabilidade, registro ou segurança de aplicativos sob procedimentos aprovados.
- Calcular as métricas de cobertura e exceção utilizando a estrutura oficial de avaliação.
- Rastreie software não suportado, ativos não autorizados, problemas de acesso, vulnerabilidades, backups falhados, falhas de alerta e descobertas do fornecedor através do reteste.
- Escreva conclusões claras sem reivindicar autoridade ou certeza além das provas.

Competência** Comprovação de Portfólio**

☐ Framework ☐ Explique os 18 Controles, IGs, classes de ativos e funções Inventário Reconcile duas fontes independentes e explique diferenças ☐ Medição ☐ Mostrar entradas, operações, medidas, métrica, lista de exceções e conclusão ☐ ☐ Alfabetização técnica ☐ Configuração de intérpretes, identidade, digitalização, log, recuperação e evidência de aplicativos • Remediação • Rastrear o dono, data de vencimento, correção e reteste verificado • Comunicação – Escreva um resumo do gestor de uma página e um documento de trabalho detalhado Ético Use dados sintéticos, autorização, limites de escopo e alegações honestas

27. Laboratório Fictício e Portfólio

- Um ambiente de prática segura usando dados sintéticos e sistemas de laboratório autorizados.*

Regra do laboratório:** Use organizações ficcionais, dados sintéticos, sistemas isolados e autorização escrita. Nunca ataque alvos públicos, use credenciais reais, ou publique saída de ferramenta sensível. ☐

1. Crie uma empresa fictícia de 50 pessoas com laptops, servidores, serviços de nuvem, uma aplicação web, pessoal remoto e cinco fornecedores.
2. Selecione IG1 e documentar três adições baseadas em risco do IG2 ou IG3.

3. Build Enterprise-asset, software, dados, conta, sistema de autenticação, rede, fornecedor, aplicativo e log-source inventários.
4. Use Nmap e osquery em um laboratório isolado para conciliar inventários de ativos e software.
5. Use OpenSCAP ou Lynis em um host de laboratório; conclusões de configuração do documento, exceções, correções e reavaliação.
6. Use Greenbone em alvos de laboratório aprovados; valide cobertura, achados, remediação e rescan.
7. Use Wazuh ou Suricata para gerar e investigar um alerta de teste seguro.
8. Use Trivy ou ZAP em um repositório de treinamento ou aplicação e corrigir registro e reteste.
9. Escreva um teste de backup-restore e incidente registro de mesa.
10. Crie cinco trabalhos CIS Assessment Specification com entradas, operações, medidas, métricas, listas de exceções e conclusões.
11. Publicar apenas artefatos higienizados e afirmar claramente que o projeto é fictício e não uma avaliação formal CIS.

Artifact** Artifact** Artifact

Memorando de seleção ☐ Priorização e raciocínio de risco • Reconciliação de inventários ☐
 Guardar papel de trabalho ; Estrutura e evidência oficiais de medição Reavaliação de configuração Relato de vulnerabilidade, cobertura, priorização, exceção e remediação Caso de Detecção, validação de alerta, investigação e resposta Restaurar teste de disponibilidade e evidência de recuperação Painel do gerente ..Limpar a comunicação de risco e ação .

28. Plano de Aprendizagem de Trinta Dias

- Uma programação focada para uma capacidade útil de nível júnior.*
- **Dias** * Foco** * Entrega****
 - ☐ 1-4 ☐ Framework, 18 Controlos, 153 Salvaguardas, IGs, classes de activos, funções 4 inventários reconciliados Configuração, vulnerabilidade, e-mail, malware • 13-16 • Registros, monitoramento, defesa de rede • Mapa de log-source e caso de alerta seguro Recuperação e resposta de incidentes • 20-22 • Fornecedores e segurança da aplicação • Avaliação do fornecedor e lista de verificação de desenvolvimento seguro • 23-25 • Especificação de Avaliação • Cinco medições completas de salvaguarda 26-28 Laboratório de ferramentas e remediação Autorizados 29-30 - Portfólio e entrevistas - Portfólio higiênico e cinco histórias de STAR
- 29. Preparação da entrevista
 - Respostas claras, cenários práticos e perguntas para o empregador.*

29.1 Quais são os controles CIS?

Um conjunto priorizado de melhores práticas defensivas organizadas em 18 Controles e 153 Salvaguardas focadas.

29,2 O que é o IG1?

O ponto de partida de higiene cibernética essencial 56-Safeguard que a CIS recomenda a cada empresa que comece.

29.3 O IG1 se encaixa em todos os requisitos?

É uma linha de base de priorização. Risco material, contratos, leis, clientes ou serviços críticos podem exigir salvaguardas adicionais.

29.4 Como mede uma Salvaguarda?

Use critérios oficiais, dependências, suposições, entradas completas, operações definidas, medidas, métricas, revisão de procedimentos, exceções e reteste.

29.5 Por que os inventários são importantes?

Eles definem as populações que os controles de configuração, vulnerabilidade, registro, recuperação e resposta devem cobrir.

29.6 Varredura de vulnerabilidade versus teste de penetração?

Um scan identifica principalmente fraquezas conhecidas; teste de penetração usa análise humana qualificada e exploração controlada para avaliar o impacto e resiliência.

29.7 Um mapeamento de framework prova conformidade?

Não. Identifica relações, mas a organização deve testar o requisito e a evidência exatos aplicáveis.

29.8 O que pode concluir um analista júnior?

Apenas o que o escopo definido e o suporte de evidência confiável, com amostragem e limitações claramente divulgadas.

29.9 Perguntas para perguntar ao empregador

Que Grupo de Implementação e adições estão no escopo?

Como são criadas e reconciliadas populações de inventário?

Quais salvaguardas têm a cobertura mais incompleta?

Como são revisados os dados e exceções de medição?

Quais ferramentas open-source e comerciais são aprovadas?

Como os resultados são priorizados, financiados e retestados?

Como avaliará o trabalho júnior?

30. Modelos, Glossário, Índice e Referências

- Estruturas de trabalho reutilizáveis, termos importantes e pontos de partida autoritários.*

30.1 Papel de medição de proteção

- Campo** * Entrada** (————— (————— (—————)
- Salvaguarda e IG Classe de âmbito e de activo • Proprietário e sistemas Dependências e pressupostos Entradas e validação Operações realizadas Medidas Métrico e interpretação Excepções e limitações Acção, proprietário, data e novo teste

30.2 Registro de achados e retestes

- Campo** * Entrada**
Critérios Condição e provas População afectada Risco e impacto Causa: Protecção provisória Correção e proprietário Data limite • Procedimento de repetição Resultado final

30.3 Glossário

* * * * *

☐ Classe de ativos ☐ Categoria afetada por uma Salvaguarda, como dispositivos, software, dados, rede, usuários ou documentação. ☐ CIS Benchmark • Recomendações de configuração segura para uma tecnologia específica. Controle CIS ☐ Uma das 18 áreas de defesa amplas. CIS Salvaguarda ☐ Uma ação focada e implementável dentro de um controle. . Cobertura .. Parte da população aplicável na qual a Salvaguarda é devidamente implementada. ☐ IG1 56 Higiene cibernética essencial ☐ IG2 ☐ IG1 mais 74 salvaguardas adicionais. ☐ Medir ☐ Contagem, lista, data, configuração ou resultado produzidos por operações de avaliação. ☐ Cálculo ou interpretação construída a partir de medidas. • População – Conjunto completo de registros, ativos, pessoas, sistemas ou eventos aplicáveis. • Revisão do procedimento; avaliação manual da existência ou não de um processo necessário e que contenha elementos necessários. ☐ Função de segurança .Govern, Identificar, Proteger, Detectar, Responder ou Recuperar mapeamento. .

30.4 Índice de assunto

Sujeito Capítulo

Contas • Segurança da aplicação Inventário de activos 6 • Registos de auditoria • Proteção de dados ☐ Evidências e medições Grupos de Implementação 2 Resposta ao incidente .. 22 .
Analistas júnior > Malware > 15 Gestor Rede • Ferramentas de código aberto Testes de penetração Recuperação 16 Os prestadores de serviços Inventário de software Formação Gestão da vulnerabilidade

30.5 Referências oficiais

CIS Controls v8.1

18 Lista de controlos CIS

Grupos de implementação

Especificação de avaliação dos controlos

Documentação da especificação de avaliação

CIS Controls Navigator

CIS Controla mapeamentos e conformidade

Lembramento final: Frameworks, mapeamentos, ferramentas, produtos, ameaças, leis, contratos e riscos organizacionais mudam. Confirmar os recursos atuais oficiais e as obrigações aplicáveis antes de uma implementação ou avaliação reais. ☐ O que é que se passa?